

03

Mecanismos de Segurança e Defesa em Camadas

Firewall, IDS, IPS, hardening, segmentação, backups e monitoramento

Curso Técnico em Desenvolvimento de Sistemas

Capítulo planejado para aproximadamente 4 horas-aula

Material de apoio didático • teoria, laboratório e revisão

Base curricular

Este capítulo foi estruturado a partir das bases tecnológicas do componente Segurança de Sistemas de Informação do curso Técnico em Desenvolvimento de Sistemas do Centro Paula Souza. A coleção expande a ementa com exemplos e atividades de laboratório.

Objetivos de aprendizagem

- Explicar o papel e as limitações de firewall, IDS e IPS.
- Aplicar a ideia de defesa em profundidade e privilégio mínimo.
- Reconhecer práticas de hardening, segmentação, atualização e backup.
- Planejar controles preventivos, detectivos e corretivos para um serviço.

Alinhamento curricular

Atende diretamente à operação de mecanismos de segurança da informação, com foco em controles de rede, sistema e continuidade.

1. Defesa em profundidade

Nenhum controle é perfeito. Defesa em profundidade combina camadas para que a falha de uma proteção não resulte imediatamente em comprometimento total. Um servidor web pode estar atrás de firewall, executar com conta de baixo privilégio, receber atualizações, registrar eventos e ter backups protegidos.

Camadas devem ser independentes o suficiente para reduzir falhas comuns. Ter dois produtos configurados da mesma forma inadequada não representa necessariamente defesa em profundidade.

2. Firewall

Firewall controla tráfego conforme regras. Pode atuar em host, rede ou camada de aplicação. Uma política segura começa pelo entendimento dos serviços necessários e evita liberar portas “por garantia”. O princípio de menor exposição reduz superfície de ataque.

Firewall não corrige vulnerabilidades da aplicação. Se o serviço HTTPS permitido contém falha de autorização, o tráfego malicioso pode passar pela porta autorizada. Por isso, filtros de rede e segurança de aplicação se complementam.

Controle	Exemplo de pergunta
Firewall	Esta conexão é necessária?
IDS	Que evento merece alerta?
IPS	Que evento pode ser bloqueado automaticamente?
Hardening	Que serviço ou privilégio pode ser removido?

3. IDS e IPS

IDS detecta atividades suspeitas e gera alertas. IPS fica no caminho do tráfego e pode bloquear eventos conforme regras. Ambos podem usar assinaturas, comportamento ou combinações. Falsos positivos e falsos negativos exigem ajuste e análise.

Alertas só geram valor quando existe processo de monitoramento: prioridade, contexto, responsável, prazo e registro da decisão. Um painel com milhares de alertas ignorados é um controle ineficaz.

4. Hardening e atualização

Hardening é reduzir a superfície de ataque: remover serviços desnecessários, desativar contas padrão, corrigir permissões, aplicar atualizações, usar configuração segura, proteger interfaces administrativas e restringir execução. Baselines ajudam a repetir a configuração.

Atualização deve considerar inventário e criticidade. Sistemas sem dono ou sem registro de versão frequentemente permanecem vulneráveis por longos períodos.

5. Backup e continuidade

Backup protege contra perda acidental, falha, corrupção e parte dos cenários de ransomware. A regra 3-2-1 é uma referência útil: múltiplas cópias, mídias ou locais distintos e ao menos uma cópia separada do ambiente principal. Mais importante que criar backup é testar restauração.

RPO representa quanto dado pode ser perdido em termos de tempo; RTO representa quanto tempo o serviço pode permanecer indisponível. Esses objetivos orientam frequência de cópia e arquitetura de recuperação.

Laboratório e aplicação prática

Prática 3 - Projeto de defesa em camadas

Objetivo: Projetar controles para uma API web com banco de dados.

1. Desenhe cliente, internet, proxy/reverso, aplicação, banco e serviço de backup.
2. Indique onde aplicar firewall e quais fluxos são realmente necessários.
3. Escolha pontos de geração de logs e alertas.
4. Liste cinco itens de hardening do servidor de aplicação.
5. Defina uma estratégia de backup com RPO e RTO coerentes para o cenário.

Entrega sugerida: Um diagrama de arquitetura com legenda de controles e justificativa curta para cada camada.

Questões de fixação

1. Por que firewall não substitui correção de vulnerabilidades na aplicação?
2. Diferencie IDS e IPS.
3. O que significa hardening?
4. Qual é a diferença entre RPO e RTO?
5. Por que testar restauração é tão importante quanto realizar backup?

Como estudar

Responda primeiro sem consultar o texto. Depois compare sua resposta com o resumo do capítulo e complemente o que faltou.

Resumo do capítulo

- Defesa em profundidade combina controles administrativos, técnicos e operacionais.
- Firewalls controlam fluxos; IDS detecta; IPS pode bloquear.
- Hardening reduz serviços, permissões e configurações desnecessárias.
- Inventário e atualização são componentes básicos da gestão de vulnerabilidades.
- Backup precisa ser protegido e testado, com objetivos de recuperação definidos.

Glossário essencial

Termo	Definição
Firewall	Controle que permite ou bloqueia tráfego conforme regras.
IDS	Sistema de detecção de intrusão.
IPS	Sistema de prevenção de intrusão.
Hardening	Processo de redução da superfície de ataque.
RPO	Objetivo de ponto de recuperação.
RTO	Objetivo de tempo de recuperação.

Referências e materiais de consulta

- Centro Paula Souza. Plano de Curso do Técnico em Desenvolvimento de Sistemas, componente Segurança de Sistemas de Informação.
- CERT.br. Cartilha de Segurança para Internet. Conteúdo de conscientização e boas práticas de segurança.
- ISO/IEC 27001. Sistemas de gestão de segurança da informação - requisitos e princípios de gestão.
- OWASP Foundation. OWASP Top 10:2025 e materiais de segurança de aplicações web.